NURTUREPATH AI / 02 / PRODUCTION

Codex Master Prompt: Production and Hosting

Security, deployment, clinical governance, operations and controlled real-world launch

Prepared as a practical implementation and review document. AI-generated clinical content must not be used as medical advice without qualified review.

00. MASTER CODEX PRODUCTION INSTRUCTION

You are Codex acting as a principal engineer, security engineer, DevOps engineer and healthcare product architect. Transform the existing NurturePath AI MVP into a production-ready, multi-tenant maternal follow-up platform. Read MVP docs and current code; preserve working behavior; conduct a gap audit and produce a prioritized remediation plan before changes. Do not assert compliance, clinical safety or production readiness without evidence. Deliver deployable code, IaC/config, automated tests, operational runbooks and a gated launch checklist. No real patient data until every mandatory gate is signed off.

01. PRODUCTION LAUNCH GATES

Gate A: formal registered-company rights and partnership/processor agreements; health-partner approval. Gate B: legal review of Ghana Data Protection Act 2012 (Act 843), cross-border transfers and applicable international law; data mapping and DPIA as appropriate. Gate C: qualified clinician approves workflows, copy, referral protocols, translations and emergency guidance. Gate D: security assessment, access review, penetration test or equivalent, backup restore exercise. Gate E: operational owner, incident response, support channels and service-level objectives. Gate F: limited real-world pilot with written protocol, consent and monitoring. Block production patient onboarding unless gates are explicitly approved.

02. ARCHITECTURE AND ENVIRONMENTS

Recommended initial hosting: Vercel (Next.js frontend/server actions where appropriate), managed PostgreSQL in a region and vendor contract approved for health data, object storage for non-sensitive assets, transactional email provider, SMS/WhatsApp via authorized providers, secrets manager and error monitoring with PHI redaction. For stricter residency or healthcare agreements, deploy Next.js/Node services and PostgreSQL on a single compliant cloud provider using managed containers, private networking and region selection. Do not assume any hosting platform is automatically compliant or suitable for health data.

Separate dev, staging and production projects/accounts, databases, credentials, messaging numbers, domains and encryption keys. Production database is never used for staging tests. Architecture: CDN/WAF -> Next.js app -> authenticated API/service -> private Postgres; background job queue for reminders and retries; provider adapters; monitoring/audit pipeline; backup vault. Prefer one deployable modular monolith until measured load requires services.

03. DOMAIN, DNS, TLS AND DEPLOYMENT

Register a domain such as nurturepath.ai or a verified alternative; never assume availability. Use app.<domain> for portal and www.<domain> for public site. Configure DNS, automatic TLS, HSTS after validation, HTTPS redirects, SPF/DKIM/DMARC for mail, CORS allowlist, CSP, secure cookies and domain ownership verification. Use GitHub Actions with protected main branch, PR reviews, dependency scans, secret scans, tests and staging deploy; production deploy only after approval. Include reproducible deploy and rollback scripts, migrations with backup-first policy, health checks and release notes.

04. PRODUCTION DATABASE AND SECURITY

Managed PostgreSQL with encrypted disks, TLS, private connectivity where possible, least-privilege DB roles, migration controls, automated PITR backups and regular restore drills. App-level encryption for contact details with rotation/versioning; KMS-managed keys. Per-tenant authorization on every query; consider PostgreSQL RLS as defense-in-depth with integration tests. Use MFA for privileged staff, secure password recovery, session expiration, revocation and device logout. Rate limit per account/IP, prevent enumeration, maintain tamper-evident audit trails with retention. Review OWASP ASVS, Top 10 and API Security Top 10. No credentials or PHI in logs, analytics, crash reports, support tickets or AI prompts.

05. RELIABLE OFFLINE AND DATA QUALITY

Implement durable client mutation queue with per-record versions and server idempotency; device storage encryption assessment; short retention and logout wipe. Offline reads limited to worker-assigned minimal records; protect lost/stolen devices with session timeout and optional device binding. Consent revocation and role deactivation must win over queued updates. Handle timezones and dates explicitly; monitor synchronization lag and failure rate. Provide conflict review UI and reconciliation runbook.

06. MESSAGING, AI AND CLINICAL GOVERNANCE

Use opt-in SMS/WhatsApp with verified sender identities, approved templates, delivery webhooks, retries/backoff, rate limits, quiet hours, STOP/opt-out, language preferences and safe fallback. Avoid sensitive pregnancy details in lock-screen notifications; neutral message previews. Provider sandbox for staging, production credentials only in secrets manager. AI limited to content drafting/translation based on curated, versioned clinical sources; human clinical review required before use. Use provider data-processing agreements, retention controls and disable training on submitted data where available. No AI diagnosis, automated medical risk classification, prescription or autonomous clinical decision-making.

Content governance: reviewer name, credentials, approval timestamp, locale, source, expiry/review date, version and rollback. Add incident path for misinformation and translation errors. Where language translations are not clinically validated, offer English and referral to a human worker instead of silently deploying machine translations.

07. MONITORING, SUPPORT AND INCIDENT RESPONSE

Define SLIs/SLOs: 99.5% monthly availability initial target, p95 API latency target <800ms for core read paths under tested load, reminder queue delivery target, sync success and referral event integrity. Monitor uptime, error rate, queue depth, database connections, storage, backup age, auth anomalies and audit events. Use structured logging with correlation IDs and PHI scrubbers; synthetic monitoring; paging/on-call owner; runbooks for outage, breach, provider failure, lost device, mistaken messages and data deletion requests. Establish breach notification procedures according to legal advice and contracts; never invent universal notification deadlines.

08. PRIVACY, RETENTION AND RIGHTS

Data inventory with purposes, lawful bases, controllers/processors, access matrix, country transfer map, retention/deletion policy, consent receipts, access/correction requests and audit trail. Define deletion vs legal record preservation with counsel and clinic partner. Separate de-identified analytics pipeline with aggregation and minimum-cell suppression. Publish plain-language privacy notice, terms, safety disclaimer and accessibility statement. Obtain third-party processor agreements before transmitting identifiable information. Perform regular access reviews and security training.

09. SCALE AND INTERNATIONALIZATION

Multi-tenant organization/clinic isolation; configurable countries, regions, facility directories, timezones, languages, message templates, emergency resources and consent text. Avoid hard-coded Ghana phone numbers or medical advice in code. Locale architecture supports RTL where needed; human-review workflow for every healthcare translation. Queue-based jobs, caching of non-sensitive reference data, database indexing, connection pooling, pagination and load testing. Scale only after pilot usage demonstrates bottlenecks.

10. CI/CD, TESTING AND RELEASE MANAGEMENT

Pipeline: lint, typecheck, unit/integration/e2e, accessibility checks, dependency and secret scans, database migration dry run, container image scan if used, staging smoke test, approval gate, production deploy, health verification, rollback. Run threat-model scenarios (IDOR, privilege escalation, cross-tenant leakage, replay, offline conflicts, webhook spoofing, XSS/CSRF, message consent bypass). Conduct mobile tests on Android/iOS browsers at 360px and desktop at 1440px; WCAG 2.2 AA audit. Test backup restore and disaster recovery objectives.

11. IMPLEMENTATION ROADMAP

Sprint 0: inventory, compliance and clinical gates; architecture decision record. Sprint 1: tenant isolation, hardened auth, encryption and consent enforcement. Sprint 2: background reminders, messaging providers, audit and observability. Sprint 3: offline sync hardening, translations governance, backups and CI/CD. Sprint 4: load/accessibility/security tests, staging trial and incident exercises. Sprint 5: limited monitored partner pilot, evaluate safety and metrics, then controlled scale. Each sprint produces code, test evidence, documentation and sign-off status.

12. COST AND OPERATIONS PLANNING

Budget by actual quotes rather than invented fixed prices: domain/DNS, app compute, database storage/PITR, message delivery per country, observability, secrets/KMS, backups, security testing, legal review, clinician review, accessibility review and support. Keep a cost dashboard and spend alerts. Start with low volume and scale after measured usage; never choose a cheaper host solely on price if it cannot meet data-handling obligations.

13. CODEX REQUIRED OUTPUTS

Provide architecture diagram (Mermaid in docs), infrastructure/environment matrix, deployment scripts or IaC, .env.example without secrets, migration/rollback runbook, key rotation plan, backup/restore proof, incident response plan, privacy/data flow map, clinical content review process, provider adapters, tests, CI workflows, SLO dashboard specification, load-test report and go-live checklist. Final response must distinguish implemented, tested, externally blocked and legally pending items. Never mark system 'ready for real use' while required approvals are missing.